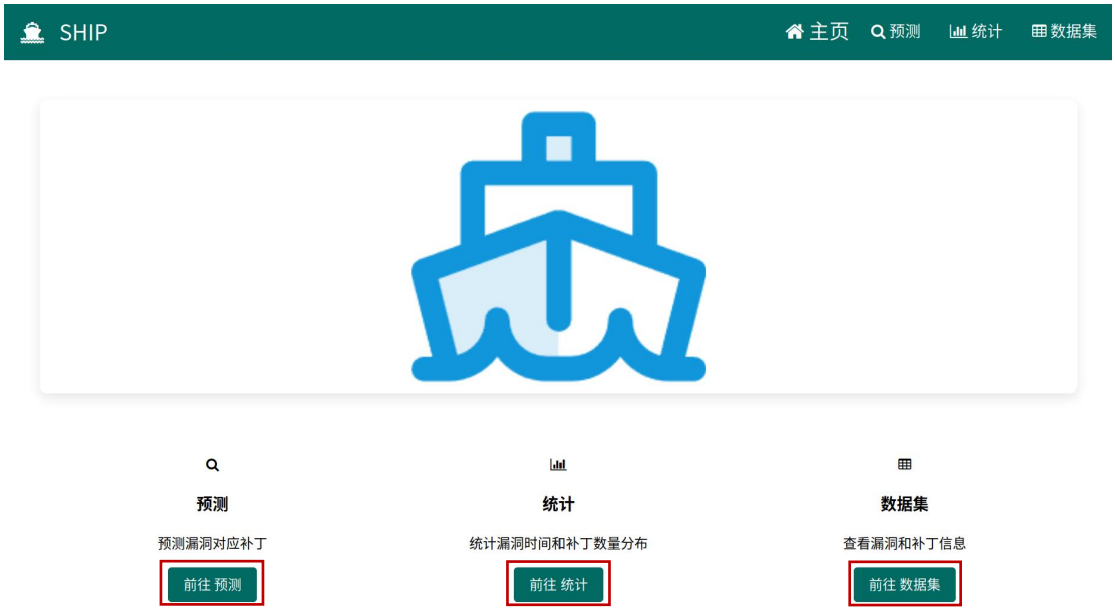
开源环境下隐匿漏洞补丁识别工具平台 SHIP 用户手册

1、主页

操作演示详见演示视频 0:00-0:09。该页面包含三个功能项模块，分别对应预测、统计和数据集三个页面，点击绿色按钮可以实现从主页到各功能页面的快速切换。



2、 预测

操作演示详见演示视频 0:10-1:09。该页面的功能包括检索给定漏洞在 NVD 平台的相关信息和预测其对应的补丁组。

页面左侧有一列导航栏，用户需要点击“输入 CVE”按钮，在弹出的新增漏洞弹窗中填写待预测的漏洞编号 (CVE ID)和仓库名称，其中仓库名称指的是漏洞存在的开源仓库的名称。点击“确认”按钮后，右侧的第一个列表会展示该漏洞在 NVD 页面中的相关信息，包括漏洞披露时间、漏洞描述、CWE 编号、补丁链接等，点击右侧的“详细信息”按钮可以查看漏洞描述、补丁列表等信息。

需要说明的是，补丁相关信息来自 NVD 页面中的补丁链接，即含有代码提交编号且被标记为“Patch”的超链接。若 NVD 页面中包含此类链接，则会提取其中的代码提交编号并统计数量，此时已经成功定位到漏洞对应的补丁；若无此类链接，则补丁数量为 0，补丁列表为空，此时需要使用 SHIP 方法进一步预测其对应的补丁。

成功输入 CVE 后，用户可点击页面左下方包含齿轮图标的绿色按钮，手动设置候选代码提交的数量和所在的时间范围。点击后将弹出配置窗口，提供三个参数配置项：候选代码提交数量、起始时间和结束时间。若用户未使用设置按钮，工具将默认选取漏洞披露时间前后六个月内的全部代码提交 (上限为 10000)，作为候选集合。随后，用户可点击“预测补丁”按钮，预测给定漏洞对应的补丁组。预测完毕后，右侧第二个列表会展示补丁编号、提交时间、作者、分支、版本、描述信息。

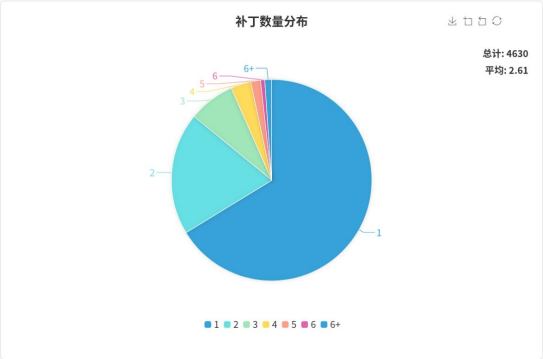
2 设置候选代码提交的数量和时间范围

在终端中，可以查看补丁预测的详细进度，部分漏洞由于候选代码提交过多，预测时间可能会超过 1 分钟。

```
huggingface/tokenizers: The current process just got forked, after parallelism h
as already been used. Disabling parallelism to avoid deadlocks...
To disable this warning, you can either:
        - Avoid using `tokenizers` before the fork if possible
        - Explicitly set the environment variable TOKENIZERS_PARALLELISM=(true |
 false)
Processing cve_links: 100%|                    | 1/1 [00:00<00:00, 226.95it/s]
100%|                                           | 1/1 [00:00<00:00, 2959.99it/s]
100%|                                           | 1/1 [00:00<00:00, 6797.90it/s]
100%|                                           | 1/1 [00:00<00:00, 8081.51it/s]
100%|                                           | 1/1 [00:00<00:00, 517.05it/s]
```

3、 统计

操作演示详见演示视频 1:09-1:20。该页面展示了所使用的数据集中与漏洞和补丁相关的统计信息，左侧为漏洞披露时间分布折线图，右侧为补丁数量分布扇形图。



4、 数据集

操作演示详见演示视频 1:21-1:39。该页面展示数据集的具体内容，涵盖 CVE ID、CVE 时间、仓库名称、补丁个数、CWE ID、CWE 类型、漏洞描述、补丁列表等关键信息。

通过在左上角的漏洞编号输入框中输入漏洞编号 (CVE ID)，点击“搜索”按钮后即可查找对应的漏洞信息，点击右侧的“详细信息”按钮可以进一步查看漏洞描述、补丁列表等信息。

CVE: CVE ID 搜索 输入漏洞编号（CVE ID）

	CVE ID	CVE 时间	仓库名称	补丁个数	CWE ID	CWE 类型	操作
1	CVE-1999-0199	2020/10/06	bminor_glibc	1	CWE-252	Unchecked Return Value	详细信息
2	CVE-2000-1254	2016/05/04	openssl_openssl	1	CWE-310	Cryptographic Issues	详细信息
3	CVE-2002-2443	2013/05/10	krb5_krb5	1	CWE-20	Improper Input Validation	详细信息
4	CVE-2006-3635	2006/07/17	torvalds_linux	1	CWE-119	Improper Restriction of Operations within the Bounds of a Memory Buffer	详细信息
5	CVE-2006-5331	2006/10/17	torvalds_linux	1	CWE-19	Data Processing Errors	详细信息
6	CVE-2007-6761	2017/04/23	torvalds_linux	1	CWE-119	Improper Restriction of Operations within the Bounds of a Memory Buffer	详细信息
7	CVE-2008-4539	2008/10/13	qemu_qemu	1	CWE-119	Improper Restriction of Operations within the Bounds of a Memory Buffer	详细信息
8	CVE-2008-5515	2008/12/12	apache_tomcat	2	CWE-22	Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')	详细信息
9	CVE-2008-5518	2008/12/12	apache_geronimo	3	CWE-22	Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')	详细信息
10	CVE-2008-7316	2016/01/24	torvalds_linux	1	CWE-20	Improper Input Validation	详细信息